

Universidad Mariano Gálvez de Guatemala
Ingeniería en Sistemas, Sede Guastatoya
Seguridad y Auditoría de Sistemas
Ingeniero Richard David Ortiz Sasvin



PROYECTO FINAL GRUPO TESTING

Rúldolf Denilsón Reyes Cabrera Carné: 1890-21-9588
Oscar David Alvarez Martinez Carné: 1890-21-4028
Manuel Antonio Fuentes Ramírez 1890-21-10093
Wilian Alberto Marroquin Morales 1890-21-15037
Mynor Estuardo Cerón Gaitan 1890-21-11828
Dulce María Carias Bran 1890-19-10478
Keisy Orfelinda Fajardo Palencia 1890-15-544
Carlos Alejandro Hernández Ortiz 1890-17-18395
Kevin Leonel Carranza Marroquín 1890-21-2621
César Arturo Chamo Morales 1890 20 13744

Guastatoya, 8 de Noviembre de 2025

Vulnerable Accounting System - Reporte de Vulnerabilidades

Grupo de Testing

Equipo: Rudolf, Manuel, Oscar, Keisy, Carlos, Kevin, Dulce, Mynor, Wilian.

Resumen de Vulnerabilidades por Severidad

Severidad	Cantidad
Critical	13
High	18
Medium	10
Low	4
TOTAL	45

Metodología de Pruebas

Este reporte incluye resultados de:

- Análisis Estático de Código:** Revisión completa del código fuente, archivos de configuración y dependencias
- Análisis Dinámico:** Pruebas con herramientas automatizadas (OWASP ZAP, nmap, Nikto) y pruebas manuales controladas
- Revisión de Configuración:** Análisis de docker-compose.yml, archivos .env, configuraciones de CORS y servidor
- Revisión de Dependencias:** Auditoría de composer.json y package.json para identificar componentes vulnerables

Vulnerabilidad 1: [Critical] Contraseñas almacenadas en texto plano

Descripción:

La tabla `users` almacena contraseñas sin hashing, permitiendo recuperación directa en caso de filtración o acceso a la base de datos.

Evidencia:

`backend/database/migrations/2024_01_01_000000_create_vulnerable_accounting_tables.php` (L21-L23)

```
$table->string('password'); // No hashing
```

También confirmado en `backend/app/Http/Controllers/AuthController.php` (L43, L62, L78, L293) donde las contraseñas se comparan y almacenan directamente.

Impacto:

Compromiso inmediato de todas las cuentas y escalada completa si la base de datos es filtrada. Violación de regulaciones de privacidad (GDPR, PCI-DSS).

Remediación:

Usar hashing robusto (bcrypt/Argon2) mediante funciones nativas de Laravel (`Hash::make`) y migrar contraseñas existentes. Nunca almacenar contraseñas en sesiones ni retornarlas en respuestas.

Referencias:

OWASP ASVS 2.1, OWASP Top10 A07:2021 – Identification and Authentication Failures, CWE-256: Plaintext Storage of a Password

Vulnerabilidad 2: [Critical] Rutas API sin autenticación ni autorización

Descripción:

Las rutas API carecen de middleware de autenticación/autorización y existe un bypass de administrador.

Evidencia:

`backend/routes/api.php` (L23-L76) - Rutas sin middleware `auth` .
`backend/app/Http/Controllers/AuthController.php` (L324-361) - Endpoint `/api/auth/admin-login` con token hardcodeado `admin_bypass_token_123` .

Endpoints críticos afectados:

- `/api/dashboard/data` - Datos financieros
- `/api/modules/*` - Todos los módulos contables
- `/api/admin/*` - Panel administrativo
- `/api/debug/*` - Interfaces de depuración

Impacto:

Acceso total a datos y acciones administrativas por atacantes no autenticados. Compromiso completo del sistema.

Remediación:

Aplicar middleware de autenticación (Sanctum/Passport), autorización por roles/políticas, y eliminar endpoints de bypass.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-284: Improper Access Control

Vulnerabilidad 3: [Critical] SQL Injection en múltiples endpoints

Descripción:

Múltiples endpoints utilizan interpolación directa de strings en consultas SQL sin preparación de parámetros.

Evidencia:

- `backend/app/Http/Controllers/AuthController.php` (L43) - Login: `"SELECT * FROM users WHERE username = '$username' AND password = '$password'"`
- `backend/app/Http/Controllers/AuthController.php` (L153) - Registro: `"INSERT INTO users (username, email, password, role, created_at) VALUES ('$username', '$email', '$password', '$role', NOW())"`
- `backend/app/Http/Controllers/AccountingController.php` (L34-44, L100-111, L214-221, L260-261) - Búsquedas, actualizaciones, eliminaciones

- `backend/app/Http/Controllers/AdminController.php` (L195, L236) - Actualización de roles y eliminación de usuarios

Impacto:

Bypass de autenticación, extracción masiva de datos, modificación o eliminación de registros, ejecución de comandos remotos.

Remediación:

Migrar todas las consultas a Eloquent ORM o Query Builder con parámetros preparados. Implementar validación estricta de entrada.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-89: SQL Injection

Vulnerabilidad 4: [Critical] Ejecución Remota de Código (RCE) vía PHP `eval()`

Descripción:

El endpoint `/api/debug/php-execute` permite ejecución directa de código PHP mediante `eval()` sin autenticación.

Evidencia:

`backend/app/Http/Controllers/DebugController.php` (L162-228)

```
eval($code); // Ejecución directa sin validación
```

Impacto:

Ejecución arbitraria de código PHP en el servidor con privilegios del servidor web. Compromiso completo del servidor y posible pivotaje a otros sistemas.

Remediación:

ELIMINAR COMPLETAMENTE este endpoint en producción. Si es necesario para desarrollo, implementar autenticación estricta, whitelist de comandos permitidos, y ejecución en entorno sandboxed.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-95: Improper Neutralization of Directives in Dynamically Evaluated Code

Vulnerabilidad 5: [Critical] Ejecución Remota de Comandos (RCE) vía `shell_exec()`

Descripción:

Los endpoints `/api/debug/execute-command` y `/api/admin/execute` ejecutan comandos del sistema operativo mediante `shell_exec()` sin sanitización.

Evidencia:

`backend/app/Http/Controllers/DebugController.php` (L314-376)

`backend/app/Http/Controllers/AdminController.php` (L89-129)

```
$output = shell_exec($command . ' 2>&1');
```

Impacto:

Ejecución arbitraria de comandos del sistema. Compromiso completo del servidor y exposición de credenciales del sistema.

Remediación:

ELIMINAR COMPLETAMENTE estos endpoints. Si son absolutamente necesarios, usar whitelist estricta de comandos permitidos y ejecutar en contenedor aislado.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-78: OS Command Injection

Vulnerabilidad 6: [Critical] Exposición masiva de credenciales y secretos

Descripción:

Múltiples endpoints exponen credenciales de base de datos, contraseñas, API keys y variables de entorno completas.

Evidencia:

- `backend/app/Http/Controllers/DebugController.php` (L50, L63) - Expone `database.password` y `$_ENV`
- `backend/app/Http/Controllers/AdminController.php` (L28-50, L383-391) - Expone todas las credenciales de DB
- `backend/routes/web.php` (L49-55) - Endpoint `/env` expone todas las variables de entorno
- `backend/app/Http/Controllers/DebugController.php` (L480) - `/api/debug/dump-state` expone configuración completa

Impacto:

Acceso no autorizado a bases de datos y servicios externos. Compromiso completo de datos sensibles y violación masiva de seguridad.

Remediación:

Eliminar todas las referencias a credenciales en respuestas de API. Implementar sanitización de respuestas. Usar servicios de gestión de secretos.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-200: Exposure of Sensitive Information

Vulnerabilidad 7: [Critical] Admin Bypass Token Hardcodeado

Descripción:

El endpoint `/api/auth/admin-login` contiene un token de bypass hardcodeado que permite acceso administrativo sin credenciales válidas.

Evidencia:

`backend/app/Http/Controllers/AuthController.php` (L329)

```
if ($token === 'admin_bypass_token_123') {  
    session(['role' => 'admin']);  
}
```

Impacto:

Acceso administrativo completo sin credenciales válidas. Escalada de privilegios inmediata y compromiso completo del sistema.

Remediación:

ELIMINAR COMPLETAMENTE este endpoint. Implementar autenticación adecuada con verificación de roles y tokens JWT seguros con firma criptográfica.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-798: Use of Hard-coded Credentials

Vulnerabilidad 8: [Critical] Ejecución SQL directa sin validación

Descripción:

Los endpoints `/api/debug/sql-execute` y `/api/admin/sql` permiten ejecución directa de SQL sin autenticación ni validación.

Evidencia:

`backend/app/Http/Controllers/DebugController.php` (L85-157)

`backend/app/Http/Controllers/AdminController.php` (L134-174)

```
$results = DB::select($query); // Sin validación
```

Impacto:

Ejecución de SQL arbitrario. Extracción completa de base de datos, modificación o eliminación de datos, y compromiso del sistema.

Remediación:

ELIMINAR COMPLETAMENTE estos endpoints. Si son necesarios para desarrollo, implementar autenticación estricta y whitelist de queries permitidas.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-89: SQL Injection

Vulnerabilidad 9: [Critical] Eliminación masiva de datos sin confirmación

Descripción:

El endpoint `/api/admin/clear-all-data` permite eliminar todos los datos de la aplicación sin confirmación ni autenticación adecuada.

Evidencia:

`backend/app/Http/Controllers/AdminController.php` (L490-544)

```
public function clearAllData(Request $request) {  
    // No hay confirmación  
    DB::table($table)->truncate();  
}
```

Impacto:

Pérdida completa de datos y DoS mediante eliminación de información crítica. Impacto catastrófico en el negocio.

Remediación:

Implementar confirmación de múltiples pasos, autenticación y autorización estricta, soft delete en lugar de eliminación permanente, y requerir múltiples administradores para confirmación.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-285: Improper Authorization

Vulnerabilidad 10: [Critical] Exposición de App Key de Laravel

Descripción:

El endpoint `/api/debug/info` y otros exponen `APP_KEY` de Laravel, utilizado para encriptación y firma.

Evidencia:

`backend/app/Http/Controllers/DebugController.php` (L59)

```
'app_key' => config('app.key'),
```

Impacto:

Descifrado de datos encriptados, falsificación de tokens y cookies, y compromiso de autenticación.

Remediación:

Nunca exponer APP_KEY en respuestas. Eliminar endpoints de debug en producción. Rotar APP_KEY si ha sido expuesto.

Referencias:

OWASP Top10 A02:2021 – Cryptographic Failures, CWE-798: Use of Hard-coded Credentials

Vulnerabilidad 11: [Critical] Exposición de variables de entorno completas

Descripción:

Los endpoints `/env` y `/api/debug/dump-state` exponen todas las variables de entorno, incluyendo credenciales, API keys y secretos.

Evidencia:

`backend/routes/web.php` (L49-55)

```
'environment_variables' => $_ENV,
```

Impacto:

Exposición completa de configuración. Compromiso de servicios externos, acceso a bases de datos y APIs externas, y violación masiva de seguridad.

Remediación:

ELIMINAR COMPLETAMENTE estos endpoints. Nunca exponer variables de entorno. Usar servicios de gestión de secretos.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-200: Information Exposure

Vulnerabilidad 12: [Critical] Path Traversal en lectura de archivos

Descripción:

El endpoint `/api/debug/read-file` y `/api/admin/logs` permiten lectura de archivos arbitrarios mediante path traversal sin validación.

Evidencia:

`backend/app/Http/Controllers/DebugController.php` (L233-309)

`backend/app/Http/Controllers/AdminController.php` (L439-485)

```
$filePath = $request->input('file_path');  
$content = file_get_contents($filePath); // Sin validación
```

Impacto:

Lectura de archivos sensibles del sistema (`.env` , `/etc/passwd` , etc.), exposición de código fuente y exposición de credenciales.

Remediación:

Validar y sanitizar rutas de archivos. Implementar whitelist de archivos permitidos. Restringir acceso a directorios específicos.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-22: Path Traversal

Vulnerabilidad 13: [Critical] Inyección de comandos en backup

Descripción:

El endpoint de backup construye comandos shell con interpolación directa de variables, permitiendo inyección de comandos.

Evidencia:

`backend/app/Http/Controllers/AdminController.php` (L290)

```
$command = "mysqldump -h $dbHost -u $dbUser -p$dbPassword $dbName > $backupPath 2>&1";
```

Impacto:

Ejecución de comandos arbitrarios, compromiso del servidor y modificación de backups.

Remediación:

Usar funciones seguras de Laravel para backups. Validar y sanitizar todas las variables. Usar prepared commands o parámetros nombrados.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-78: OS Command Injection

Vulnerabilidad 14: [High] IDOR (Insecure Direct Object References)

Descripción:

Los endpoints permiten acceso a recursos de otros usuarios mediante manipulación de IDs sin verificación de propiedad.

Evidencia:

`backend/app/Http/Controllers/AccountingController.php` (L206-247) - Cualquier usuario puede

acceder/modificar/eliminar registros de otros mediante manipulación del parámetro `{id}` .

Impacto:

Acceso no autorizado a datos de otros usuarios, modificación de registros financieros y eliminación de datos críticos.

Remediación:

Verificar propiedad del recurso antes de operaciones. Implementar políticas de autorización (Laravel Policies).

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-639: Authorization Bypass Through User-Controlled Key

Vulnerabilidad 15: [High] Cross-Site Scripting (XSS) Reflejado y Almacenado

Descripción:

La aplicación no sanitiza outputs de usuario, permitiendo XSS reflejado en búsquedas y almacenado en formularios.

Evidencia:

`backend/app/Http/Controllers/AccountingController.php` (L100-111) - Los términos de búsqueda se reflejan directamente sin encoding.

`backend/app/Http/Controllers/AccountingController.php` (L371-418) - Formulario de contacto almacena inputs sin sanitización.

Impacto:

Robo de cookies de sesión, secuestro de cuentas, ejecución de código JavaScript malicioso, y phishing.

Remediación:

Implementar output encoding en todos los endpoints. Usar Content Security Policy (CSP). Implementar sanitización en frontend y backend.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-79: Cross-site Scripting

Vulnerabilidad 16: [High] CORS extremadamente permisivo

Descripción:

La configuración de CORS permite solicitudes desde cualquier origen (`*`), con soporte de credenciales habilitado.

Evidencia:

`backend/config/cors.php` (L27, L42)

```
'allowed_origins' => ['*'],
'supports_credentials' => true,
```

Impacto:

Ataques Cross-Site Request Forgery (CSRF) facilitados, exposición de credenciales y sesiones, y robo de datos mediante peticiones cross-origin.

Remediación:

Restringir orígenes permitidos a dominios específicos. Deshabilitar `supports_credentials` o usarlo solo con orígenes específicos. Implementar validación estricta de origen.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-942: Permissive Cross-domain Policy

Vulnerabilidad 17: [High] Subida de archivos sin validación

Descripción:

El endpoint `/api/upload` permite subida de cualquier tipo de archivo sin validación de tipo, tamaño o contenido, almacenándolos en directorio público.

Evidencia:

```
backend/app/Http/Controllers/AccountingController.php (L300-366)
```

```
$file = $request->file('file');  
$fileName = time() . '_' . $originalName; // Sin sanitización
```

Impacto:

Subida de shells PHP maliciosos, ejecución remota de código mediante archivos subidos, sobrecarga del servidor (DoS), y almacenamiento de contenido malicioso.

Remediación:

Validar tipo MIME y extensión. Validar tamaño máximo. Renombrar archivos con nombres seguros. Almacenar fuera de directorio web público. Escanear con antivirus.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-434: Unrestricted Upload of File with Dangerous Type

Vulnerabilidad 18: [High] Gestión insegura de sesiones

Descripción:

Las sesiones almacenan información sensible (contraseñas), no tienen timeout configurado, y los tokens son predecibles (base64 de username + timestamp).

Evidencia:

```
backend/app/Http/Controllers/AuthController.php (L52-67)
```

```
$token = base64_encode($username . ':' . time() . ':' . 'secret_key');  
session(['password' => $password]);
```

Impacto:

Secuestro de sesión mediante token predecible, exposición de contraseñas en sesiones, y sesiones que no expiran.

Remediación:

Usar tokens criptográficamente seguros (JWT con firma). Nunca almacenar contraseñas en sesiones. Implementar timeout de sesión. Usar cookies HttpOnly y Secure.

Referencias:

OWASP Top10 A02:2021 – Cryptographic Failures, CWE-384: Session Fixation

Vulnerabilidad 19: [High] Debug mode habilitado en producción

Descripción:

El modo debug está habilitado (`APP_DEBUG=true`) en configuración de producción, exponiendo stack traces, queries SQL e información sensible en errores.

Evidencia:

`docker-compose.yml` (L33)

```
APP_DEBUG=true
```

Impacto:

Exposición de estructura de base de datos, exposición de rutas de archivos, exposición de información del sistema, y facilitación de enumeración de vulnerabilidades.

Remediación:

Deshabilitar debug en producción: `APP_DEBUG=false` , `APP_ENV=production` . Implementar manejo de errores genérico y logging seguro sin exponer detalles.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-209: Information Exposure Through an Error Message

Vulnerabilidad 20: [High] Credenciales débiles por defecto

Descripción:

El sistema incluye credenciales por defecto débiles y predecibles (admin/admin123, user1/password123, guest/guest).

Evidencia:

`README.md` (L139-143) y `backend/database/seeder/VulnerableDataSeeder.php`

Impacto:

Acceso no autorizado mediante credenciales conocidas, compromiso inicial del sistema y base para escalada de privilegios.

Remediación:

Forzar cambio de contraseñas en primer login. Implementar política de contraseñas fuertes. Deshabilitar cuentas por defecto. Implementar autenticación multi-factor.

Referencias:

OWASP Top10 A07:2021 – Identification and Authentication Failures, CWE-521: Weak Password Requirements

Vulnerabilidad 21: [High] Reset de contraseña sin verificación

Descripción:

El endpoint `/api/auth/reset-password` permite cambiar contraseñas sin verificar la identidad del usuario ni validar el token de recuperación.

Evidencia:

`backend/app/Http/Controllers/AuthController.php` (L189-221)

```
$updateQuery = "UPDATE users SET password = '$newPassword' WHERE email = '$email'";  
// Sin verificación de identidad
```

Impacto:

Compromiso de cuentas mediante cambio no autorizado de contraseñas y acceso no autorizado al sistema.

Remediación:

Implementar tokens de recuperación seguros y con expiración. Verificar identidad mediante email o SMS. Requerir contraseña actual para cambio. Implementar rate limiting.

Referencias:

OWASP Top10 A07:2021 – Identification and Authentication Failures, CWE-640: Weak Password Recovery Mechanism

Vulnerabilidad 22: [High] Manipulación de sesión sin autorización

Descripción:

El endpoint `/api/debug/session` permite manipulación completa de sesiones sin autenticación, incluyendo establecer roles de administrador.

Evidencia:

backend/app/Http/Controllers/DebugController.php (L381-459)

```
session([$key => $value]); // Puede establecer role=admin
```

Impacto:

Escalada de privilegios, secuestro de sesiones y bypass de autenticación.

Remediación:

Eliminar endpoint de manipulación de sesión. Implementar protección de datos de sesión críticos. Validar cambios de rol en servidor.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-384: Session Fixation

Vulnerabilidad 23: [High] Exposición de backups de base de datos

Descripción:

El endpoint `/api/admin/backup` crea backups sin encriptación y expone credenciales de base de datos en el comando ejecutado.

Evidencia:

backend/app/Http/Controllers/AdminController.php (L275-338)

```
$command = "mysqldump -h $dbHost -u $dbUser -p$dbPassword $dbName > $backupPath";
```

Impacto:

Exposición de credenciales en logs y procesos, backups no encriptados accesibles y compromiso completo de datos.

Remediación:

Encriptar backups. No exponer credenciales en comandos. Restringir acceso a backups. Usar variables de entorno para credenciales.

Referencias:

OWASP Top10 A02:2021 – Cryptographic Failures, CWE-312: Cleartext Storage of Sensitive Information

Vulnerabilidad 24: [High] Almacenamiento de sesiones en localStorage

Descripción:

El frontend almacena tokens de sesión en localStorage, accesible mediante JavaScript y vulnerable a XSS.

Evidencia:

```
frontend/src/store/index.js - Revisar almacenamiento de tokens
```

Impacto:

Robo de tokens mediante XSS, acceso no autorizado a cuentas y persistencia de sesión vulnerable.

Remediación:

Usar httpOnly cookies para tokens. Implementar SameSite cookies. Usar sessionStorage en lugar de localStorage si es necesario. Implementar refresh tokens.

Referencias:

OWASP Top10 A02:2021 – Cryptographic Failures, CWE-922: Insecure Storage of Sensitive Information

Vulnerabilidad 25: [High] Exposición de información de usuario completa

Descripción:

Los endpoints retornan información completa de usuarios incluyendo passwords, API keys y secret keys sin restricción.

Evidencia:

```
backend/app/Http/Controllers/AuthController.php (L287-299)
```

```
'password' => $user->password,  
'api_key' => $user->api_key,  
'secret_key' => $user->secret_key
```

Impacto:

Exposición masiva de credenciales, compromiso de cuentas y acceso a servicios externos mediante API keys.

Remediación:

No retornar campos sensibles en respuestas. Implementar campos ocultos en modelos. Usar recursos de API (API Resources) para filtrar datos. Validar permisos antes de exponer información.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-200: Information Exposure

Vulnerabilidad 26: [High] Falta de validación de entrada

Descripción:

La aplicación no valida ni sanitiza la mayoría de los inputs de usuario, permitiendo datos malformados y facilitando inyecciones.

Evidencia:

Múltiples controladores sin validación (AuthController, AccountingController, AdminController, DebugController)

Impacto:

Facilitación de todas las inyecciones, corrupción de datos y comportamiento inesperado.

Remediación:

Implementar Form Requests de Laravel con validación estricta. Sanitizar todos los inputs. Usar whitelist en lugar de blacklist.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-20: Improper Input Validation

Vulnerabilidad 27: [High] Exposición de queries SQL en respuestas

Descripción:

Las respuestas de error y debug exponen queries SQL completos, facilitando la construcción de ataques SQL Injection más sofisticados.

Evidencia:

Múltiples controladores exponen `'sql_query' => $query` en respuestas

Impacto:

Facilitación de ataques SQL Injection, exposición de estructura de base de datos y enumeración de tablas y columnas.

Remediación:

No exponer queries SQL en respuestas. Logging seguro sin exponer en UI. Mensajes de error genéricos en producción.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-209: Information Exposure Through an Error Message

Vulnerabilidad 28: [High] Exposición de logs con información sensible

Descripción:

Los logs registran contraseñas, queries SQL completos, tokens y otra información sensible sin sanitización.

Evidencia:

backend/app/Http/Controllers/AuthController.php (L19-25)

```
Log::info('Login attempt', [  
    'password' => $request->input('password'),  
]);
```

Impacto:

Exposición de credenciales si hay acceso a logs, violación de privacidad y facilitación de ataques dirigidos.

Remediación:

No registrar información sensible. Sanitizar logs antes de escribir. Implementar rotación y encriptación de logs.

Referencias:

OWASP Top10 A09:2021 – Security Logging and Monitoring Failures, CWE-532: Information Exposure Through Log Files

Vulnerabilidad 29: [Medium] Falta de rate limiting

Descripción:

Los endpoints de autenticación y funcionalidades críticas no implementan rate limiting, permitiendo ataques de

fuerza bruta y abuso de recursos.

Evidencia:

backend/routes/api.php (L24) - Comentario explícito: "without rate limiting"

Impacto:

Ataques de fuerza bruta en login, DoS mediante peticiones masivas y abuso de recursos del servidor.

Remediación:

Implementar rate limiting mediante middleware. Implementar captcha después de intentos fallidos. Bloqueo temporal de cuentas.

Referencias:

OWASP Top10 A07:2021 – Identification and Authentication Failures, CWE-307: Improper Restriction of Excessive Authentication Attempts

Vulnerabilidad 30: [Medium] Información del sistema expuesta

Descripción:

Múltiples endpoints exponen información detallada del sistema incluyendo versiones, configuración y rutas.

Evidencia:

- backend/routes/web.php (L44-46) - /phpinfo - Información completa de PHP
- backend/routes/web.php (L49-55) - /env - Variables de entorno
- backend/app/Http/Controllers/DebugController.php (L16-80) - /api/debug/info - Configuración completa
- backend/app/Http/Controllers/AdminController.php (L343-434) - /api/admin/system-info - Información del servidor

Impacto:

Facilitación de ataques dirigidos, exposición de versiones de software vulnerables y exposición de configuración.

Remediación:

Eliminar endpoints de información en producción. Restringir acceso con autenticación si es necesario. Sanitizar respuestas para ocultar información sensible.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-200: Information Exposure

Vulnerabilidad 31: [Medium] Componentes con vulnerabilidades conocidas

Descripción:

El sistema utiliza versiones obsoletas y vulnerables de dependencias con CVEs conocidos.

Evidencia:

- backend/composer.json - Laravel 8.x (vulnerabilidades conocidas)
- frontend/package.json - Vue.js 2.6.14 (versión obsoleta, sin soporte), Axios 0.21.1 (vulnerabilidad de prototype pollution)

Impacto:

Explotación de vulnerabilidades conocidas, falta de parches de seguridad y compromiso mediante dependencias.

Remediación:

Actualizar a versiones soportadas: Laravel 9.x o 10.x (LTS), Vue.js 3.x, Axios 1.x. Implementar escaneo automático de dependencias (composer audit, npm audit). Establecer política de actualización regular.

Referencias:

OWASP Top10 A06:2021 – Vulnerable and Outdated Components, CWE-1104: Use of Unmaintained Third-Party Components

Vulnerabilidad 32: [Medium] Falta de headers de seguridad HTTP

Descripción:

La aplicación no implementa headers de seguridad como Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security.

Evidencia:

No hay configuración de headers de seguridad en la aplicación

Impacto:

Vulnerable a clickjacking, vulnerable a MIME sniffing, sin protección contra XSS mediante CSP y sin forzado de HTTPS.

Remediación:

Implementar middleware para headers de seguridad. Configurar CSP apropiado.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, <https://owasp.org/www-project-secure-headers/>

Vulnerabilidad 33: [Medium] CSRF no protegido

Descripción:

Las rutas API no implementan protección CSRF, y el frontend no incluye tokens CSRF en las peticiones.

Evidencia:

`backend/routes/api.php` - No hay middleware CSRF aplicado

Impacto:

Ataques Cross-Site Request Forgery, ejecución de acciones en nombre del usuario sin consentimiento y modificación de datos mediante sitios maliciosos.

Remediación:

Implementar tokens CSRF para rutas web. Para APIs, usar tokens de autenticación (JWT, API tokens). Validar origen de peticiones.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-352: Cross-Site Request Forgery

Vulnerabilidad 34: [Medium] Catch-all route con información de debug

Descripción:

Las rutas catch-all (`/ {any}`) exponen información de debug, rutas disponibles y datos de sesión en respuestas 404.

Evidencia:

`backend/routes/api.php` (L79-97)

```
'debug' => [
    'available_routes' => [...],
    'session' => $request->session()->all()
]
```

Impacto:

Enumeración de endpoints, exposición de estructura de la aplicación y exposición de datos de sesión.

Remediación:

Respuestas 404 genéricas sin información. No exponer estructura interna. Logging de intentos sin exponer en respuesta.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-209: Information Exposure Through an Error Message

Vulnerabilidad 35: [Medium] Mapeo inseguro de módulos a tablas

Descripción:

El método `getTableNameForModule()` permite inyección de nombres de tabla mediante manipulación del parámetro `$module`.

Evidencia:

```
backend/app/Http/Controllers/AccountingController.php (L423-439)
```

```
return $moduleTableMap[$module] ?? $module; // Retorna input si no está en mapa
```

Impacto:

Acceso a tablas no autorizadas, SQL Injection mediante nombres de tabla y modificación de estructura de datos.

Remediación:

Validar estrictamente nombres de módulos. Usar whitelist estricta.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-89: SQL Injection

Vulnerabilidad 36: [Medium] Exposición de phpinfo()

Descripción:

El endpoint `/phpinfo` expone información completa de configuración de PHP incluyendo extensiones, rutas y configuración del servidor.

Evidencia:

```
backend/routes/web.php (L44-46)
```

```
Route::get('/phpinfo', function () {
    phpinfo();
});
```

Impacto:

Exposición de configuración del sistema, facilitación de ataques dirigidos y exposición de rutas y extensiones.

Remediación:

Eliminar endpoint phpinfo en producción. Si es necesario, restringir con autenticación y acceso IP. Usar solo en desarrollo.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-200: Information Exposure

Vulnerabilidad 37: [Medium] Falta de validación de tipo de archivo

Descripción:

La subida de archivos no valida el tipo real de archivo, solo confía en la extensión y MIME type reportado por el cliente.

Evidencia:

```
backend/app/Http/Controllers/AccountingController.php (L314-317)
```

```
$extension = $file->getClientOriginalExtension();  
// No valida contenido real del archivo
```

Impacto:

Subida de archivos maliciosos disfrazados y ejecución de código mediante archivos subidos.

Remediación:

Validar contenido real del archivo (magic bytes). Verificar firma de archivo. Usar librerías de validación de archivos. Escanear con antivirus.

Referencias:

OWASP Top10 A03:2021 – Injection, CWE-434: Unrestricted Upload of File with Dangerous Type

Vulnerabilidad 38: [Medium] Credenciales de base de datos en docker-compose.yml

Descripción:

El archivo `docker-compose.yml` contiene credenciales de base de datos en texto plano, expuestas en el repositorio.

Evidencia:

```
docker-compose.yml (L49-53)
```

```
MYSQL_ROOT_PASSWORD=vulnerable_password_123  
MYSQL_PASSWORD=vuln_pass_123
```

Impacto:

Exposición de credenciales si el repositorio es público, acceso no autorizado a base de datos y compromiso de datos.

Remediación:

Usar variables de entorno para credenciales. Usar archivos `.env` en `.gitignore`. Implementar secretos de Docker. Rotar credenciales regularmente.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-798: Use of Hard-coded Credentials

Vulnerabilidad 39: [Medium] Redis sin autenticación

Descripción:

El servicio Redis está configurado sin contraseña, permitiendo acceso no autorizado si está expuesto.

Evidencia:

```
docker-compose.yml (L77-86)
```

```
redis:
  command: redis-server --appendonly yes
  # Sin configuración de contraseña
```

Impacto:

Acceso no autorizado a caché y sesiones, manipulación de datos en Redis y posible RCE mediante módulos de Redis.

Remediación:

Configurar contraseña para Redis. Restringir acceso de red. Usar TLS si es posible.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-306: Missing Authentication for Critical Function

Vulnerabilidad 40: [Medium] Falta de logging de eventos de seguridad

Descripción:

La aplicación no registra adecuadamente eventos de seguridad críticos como intentos de acceso fallidos, cambios de roles, o accesos administrativos.

Evidencia:

Aunque hay algunos logs, no hay logging estructurado de eventos de seguridad

Impacto:

Falta de detección de ataques, imposibilidad de investigación forense y cumplimiento de regulaciones comprometido.

Remediación:

Implementar logging de eventos de seguridad: intentos de login fallidos, cambios de privilegios, accesos a datos sensibles, operaciones administrativas. Centralizar logs en SIEM. Implementar alertas automáticas.

Referencias:

OWASP Top10 A09:2021 – Security Logging and Monitoring Failures, CWE-778: Insufficient Logging

Vulnerabilidad 41: [Low] Exposición de rutas de archivos en errores

Descripción:

Los mensajes de error exponen rutas completas del sistema de archivos, facilitando la enumeración de la estructura.

Evidencia:

Múltiples excepciones exponen `'file' => $e->getFile()`

Impacto:

Enumeración de estructura de archivos, facilitación de path traversal y exposición de tecnologías y estructura.

Remediación:

No exponer rutas de archivos en errores de producción. Logging seguro con rutas solo en logs. Mensajes de error genéricos para usuarios.

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-209: Information Exposure Through an Error Message

Vulnerabilidad 42: [Low] Falta de timeout en sesiones

Descripción:

Las sesiones no tienen timeout configurado, permitiendo sesiones abiertas indefinidamente.

Evidencia:

No hay configuración de `session.lifetime` o timeout en la aplicación

Impacto:

Sesiones persistentes indefinidamente, mayor riesgo si se compromete una sesión y no hay expiración automática.

Remediación:

Configurar timeout de sesión. Implementar regeneración periódica de ID de sesión. Invalidar sesiones inactivas.

Referencias:

OWASP Top10 A02:2021 – Cryptographic Failures, CWE-613: Insufficient Session Expiration

Vulnerabilidad 43: [Low] Permisos solo en cliente

Descripción:

Los permisos de módulos solo se validan en el cliente, sin verificación en el servidor, permitiendo bypass mediante manipulación de peticiones.

Evidencia:

```
backend/app/Http/Controllers/AccountingController.php (L444-456)
```

```
'note' => 'These permissions are not enforced server-side'
```

Impacto:

Bypass de controles de acceso y acceso a funcionalidades restringidas.

Remediación:

Validar permisos en servidor para cada operación. Implementar políticas de autorización. No confiar en validaciones del cliente.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-602: Client-Side Enforcement of Server-Side Security

Vulnerabilidad 44: [Low] Falta de validación de contenido XML (XXE)

Descripción:

Si la aplicación procesa XML, no hay protección contra XXE (XML External Entity) attacks, permitiendo lectura de archivos locales y SSRF.

Evidencia:

Mencionado en `VULNERABILITIES.md` (L108-127) aunque no se encontró código específico de procesamiento XML en los controladores principales

Impacto:

Lectura de archivos locales mediante XXE, SSRF mediante entidades externas y Denial of Service.

Remediación:

Deshabilitar entidades externas en parsers XML. Usar parsers XML seguros. Validar y sanitizar input XML. Usar formatos alternativos (JSON).

Referencias:

OWASP Top10 A05:2021 – Security Misconfiguration, CWE-611: Improper Restriction of XML External Entity Reference

Vulnerabilidad 45: [Low] Race Conditions y Business Logic Flaws

Descripción:

Las transacciones financieras no implementan operaciones atómicas, permitiendo condiciones de carrera y posibles errores de lógica de negocio.

Evidencia:

Mencionado en `VULNERABILITIES.md` (L290-307) - No hay validación de balances, se permiten montos negativos, y no hay operaciones atómicas en transacciones concurrentes.

Impacto:

Problemas de integridad de datos, errores en cálculos financieros y posibles pérdidas o ganancias incorrectas.

Remediación:

Implementar transacciones de base de datos. Validar balances antes de operaciones. Implementar locks para operaciones críticas. Validar reglas de negocio en servidor.

Referencias:

OWASP Top10 A01:2021 – Broken Access Control, CWE-362: Concurrent Execution using Shared Resource with Improper Synchronization

Conclusión

Este análisis ha identificado **45 vulnerabilidades** que requieren atención inmediata del Grupo de Cybersecurity. Las vulnerabilidades más críticas incluyen ejecución remota de código, SQL Injection masivo, exposición masiva de credenciales, y falta total de autenticación y autorización.

Preparado por: Grupo de Testing



Resumen Ejecutivo

El presente documento corresponde al reporte final de pruebas del proyecto Vulnerable Accounting System, desarrollado como parte del curso de Proyecto Final. El sistema fue diseñado intencionalmente con vulnerabilidades para fines educativos y de análisis en ciberseguridad, permitiendo a los equipos aplicar metodologías de prueba basadas en los estándares OWASP Top 10.

Organización del Equipo

El objetivo principal fue realizar pruebas de seguridad sobre una aplicación intencionalmente vulnerable, documentando las fallas encontradas y proponiendo remediaciones técnicas que sirvan de apoyo al equipo de Ciberseguridad.

La organización del trabajo se estructuró mediante la herramienta ClickUp, donde se crearon espacios de trabajo, carpetas y tareas individuales. Cada integrante recibió la asignación de cinco vulnerabilidades para su análisis y documentación, con el fin de mantener una distribución equitativa de responsabilidades y facilitar el control del progreso general.

La coordinación y seguimiento del trabajo se realizaron a través de reuniones periódicas en Google Meet, en las cuales se revisaron avances, se validaron hallazgos y se consolidó la información técnica para el reporte final.

El liderazgo del proyecto se basó en una metodología de trabajo colaborativa y secuencial, donde cada integrante aportó desde su asignación para lograr un resultado integral y bien documentado.

Rubrica de calificación

Integrante	Cumplimiento	Calidad	Participación	Colaboración	Responsabilidad	Nota
Manuel	10	10	10	10	10	100%
Oscar	10	10	10	10	10	100%
Keisy	10	10	10	10	10	100%
Dulce	10	10	10	10	10	100%
Wilian	10	10	10	10	10	100%
Kevin	10	10	10	10	10	100%
Carlos	10	10	10	10	10	100%
Mynor	10	10	10	10	10	100%
Cesar	10	10	10	10	10	100%

Testing - Vulnerable Accounting / Recolección de Vulnerabilidades / Vulnerabilidades Asignadas

Agentes Automatizar Ask AI Compartir 1

Lista Tablero + Vista

NUEVO 9 ... +

Nombre

Persona asignada

Fecha límite

Prioridad

SQL Injection, RCE, contraseñas y exposición de credenciales.		Hoy	
Vulnerabilidades de Autenticación y Acceso		Hoy	
Vulnerabilidades de Configuración y Archivos		Ayer	
Vulnerabilidades de Sesión y Validación		Hoy	
Vulnerabilidades Administrativas		Hoy	
Vulnerabilidades de Backups y Configuración Segura		Hoy	
Vulnerabilidades del Frontend y Credenciales		Hoy	
Vulnerabilidades de Comandos y Dependencias		Ayer	
Vulnerabilidades del Entorno e Información de Usuario		Hoy	

+ Añadir Tarea

+ Tarea

NUEVO 0

+ Añadir Tarea

EN REVISIÓN 0

+ Añadir Tarea

APROBADO 9

- SQL Injection, RCE, contraseñas y exposición de credenciales.
 Hoy Alta
- Vulnerabilidades de Autenticación y Acceso
 Hoy Alta
- Vulnerabilidades de Configuración y Archivos
 Ayer Alta
- Vulnerabilidades del Entorno e Información de Usuario
 Hoy Alta
- Vulnerabilidades de Comandos y Dependencias
 Ayer Alta
- Vulnerabilidades de Sesión y Validación
 Hoy Alta

+ Añadir grupo